

Pentesting Methodology & Rules of Engagement

Why Pentesting Exists

You find the holes *before* the criminals do. A pentest is an **authorized**, scoped simulation of an attack, with a professional report.

The Standard Methodology (PTES/OWASP)

Pre-engagement â€” scope, permissions, rules of engagement (RoE)

Reconnaissance â€” passive (OSINT) then active (scanning)

Scanning/Enumeration â€” ports, services, vulnerabilities

Exploitation â€” gain access

Post-exploitation â€” pivot, escalate, collect proof

Reporting â€” findings, risk, recommended fixes

Rules of Engagement (THE LEGAL BOUNDARY)

Before ANY test, written agreement must cover:

Scope â€” WHICH systems (by IP/range/domain), and EXCLUDES (e.g., "not the patient database")

Authorized test types â€” network, web, social engineering, physical?

Hours â€” test only during X

Impact limits â€” "do not deliberately crash the production ERP"

Emergency contacts â€” if you find something live and bad

Handling of findings â€” disclosure, PII handling

Legal guardrails â€” signed contract = your permission slip

Bright-line rule: without written authorization, it's a crime. Period. "Hack-back" is also illegal. Permission is the whole difference

between a pentester and a criminal.

The Reporting Discipline

A pentest is judged by its REPORT, not by the hacks:

Components:

Executive summary â€” what did we find, how bad, in business terms

Technical findings â€” each: asset, vuln, CVE, CVSS, reproduction steps, screenshots

Risk ratings â€” Critical/High/Medium/Low by likelihood Ã— impact

Remediation guidance â€” prioritized fixes

Appendices â€” tools, raw data

The retest â€” after fixes, re-run to confirm closure. That's the value loop.

The Ethics Rules

Written authorization â€” always

Least-impact testing â€” don't blow up production

Protect data â€” never exfiltrate real PII; mask it

Report to the RIGHT people â€” no public proof-of-hack theater

Hand over everything to the client, no retention

Your career dies in one day on a criminal act. Reputation + a clean legal record is everything in offensive security.

[← Module start](#)

[Reconnaissance & OSINT →](#)